STRATEGIC INCIDENT REPORT: OPERATION DIGITAL FLOOD

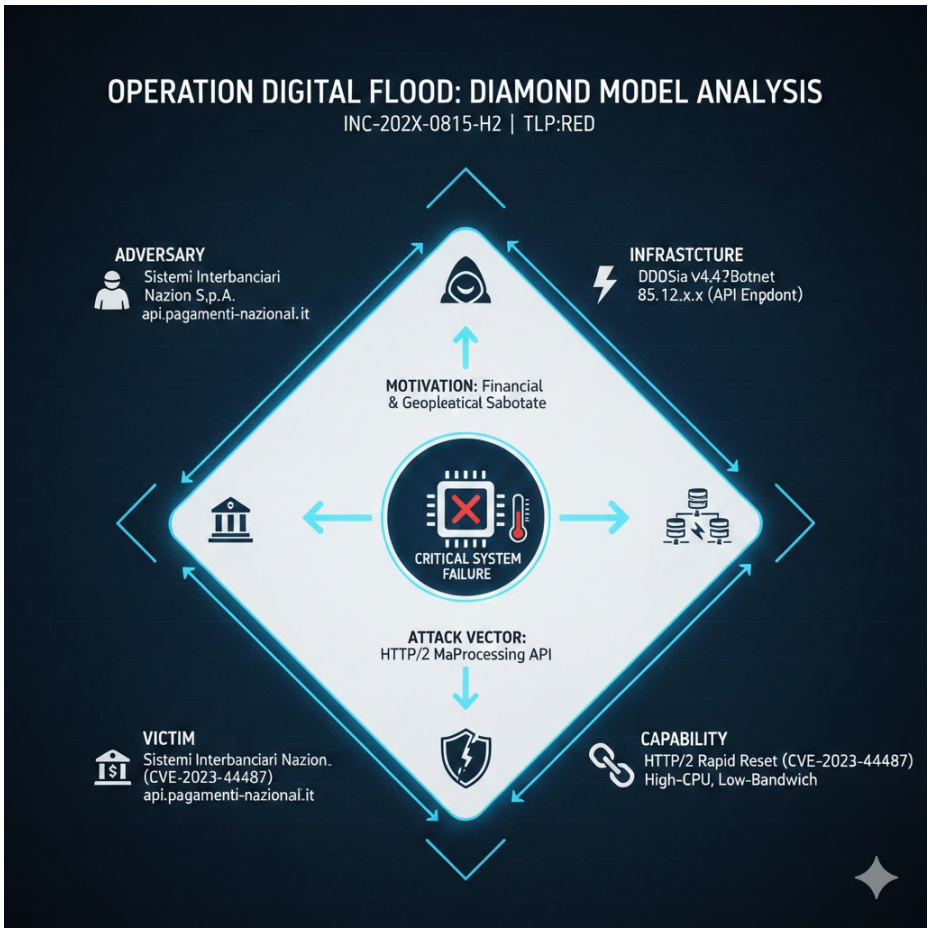
Destinatari: Board of Directors, CISO, Autorità Nazionale Cybersecurity (ACN)
Data: 14 Ottobre 202X
Riferimento: INC-202X-0815-H2
Classificazione: TLP RED - LIV. 7 STRETTAMENTE RISERVATO

1. EXECUTIVE SUMMARY

Alle ore 08:15 CEST, l'infrastruttura di pagamento nazionale ha subito un arresto totale dei servizi. Nonostante il traffico di rete fosse entro i limiti nominali (40%), i sistemi di backend hanno raggiunto il **100% di saturazione CPU**. L'attacco è stato identificato come un **HTTP/2 Rapid Reset** (ovvero si fa una richiesta, si annulla e si rifà cosi facendo per migliaia di volte in un lasso di tempo di millisecondi) sferrato dal gruppo "RedStorm". L'incidente ha causato il blocco totale di POS e ATM in coincidenza con il G7 Finanze di Milano. La situazione è attualmente in fase di contenimento tramite degradazione controllata del protocollo.

2. ANALISI SECONDO IL "DIAMOND MODEL"

Il Diamond Model delinea le relazioni chiave dell'intrusione per supportare l'attribuzione e la strategia di difesa:



ADVERSARY (Attaccante): RedStorm è uno dei gruppi di hacktivisti più attivi. Non sono hacker che cercano di rubare soldi per arricchirsi personalmente, ma agiscono per motivazioni politiche (supporto alla Russia) operano come proxy di uno stato ostile. Dimostrano capacità tecniche avanzate e coordinamento geo-politico.

INFRASTRUCTURE: Botnet (rete di dispositivi infetti che a loro volta infettano) basata sul client **DDoSia v4.4.2**.(malware che gestisce migliaia di richieste simultanee) Utilizzo di nodi distribuiti per eludere geoblocking e simulare traffico client legittimo.

CAPABILITY: L'attaccante dimostra una capacità tecnica avanzata sfruttando la gestione degli stream del protocollo HTTP/2. Attraverso l'abuso del frame RST_STREAM, il target viene costretto a un'elaborazione computazionale ciclica (apertura/chiusura stream) che degrada le prestazioni della CPU. Questa tecnica permette di massimizzare il danno d'impatto riducendo al minimo l'impronta di traffico (banda), rendendo l'attacco difficile da rilevare tramite i comuni sistemi di soglia basati sul volume di traffico.

VICTIMS L'infrastruttura api.pagamenti-nazionali.it rappresenta un *Single Point of Failure* (SPOF) per l'ecosistema finanziario del Paese.

Valutazione del Danno: Un attacco condotto con successo tramite tecnica *HTTP/2 Rapid Reset* non si limiterebbe a un disservizio informatico, ma provocherebbe una **paralisi operativa transazionale**.

Conseguenze Sistemiche:

Operatività Retail: Indisponibilità dei circuiti di pagamento POS e ATM su scala nazionale.

Mercati: Impossibilità di regolare le transazioni di clearing interbancario, con potenziale violazione degli SLA (Service Level Agreements) imposti dalle autorità di vigilanza (Banca d'Italia/BCE).

Ordine Pubblico: Il blocco prolungato dei servizi finanziari di base è classificato come un rischio per la stabilità economica nazionale.

3. ANALISI TECNICA DETTAGLIATA

I. L’Anomalia del Protocollo (The Zero-Day):

L'analisi dei pacchetti (Artifact B) conferma lo sfruttamento della vulnerabilità **HTTP/2 Rapid Reset (CVE-2023-44487)**. A differenza di un attacco volumetrico, questo sfrutta il **Multiplexing** di HTTP/2 ovvero la capacità di inviare e ricevere **più file contemporaneamente** utilizzando un'unica connessione.

Meccanismo: L'attaccante invia un frame HEADERS (apertura stream) seguito immediatamente da un frame RST_STREAM (annullamento).

L'Effetto: Dall'Artifact B si osserva che un singolo frame TCP (Frame 1051) contiene **centinaia di richieste e reset**.

Saturazione: Il server deve allocare risorse CPU per processare l'apertura di ogni stream, ma il reset immediato impedisce al sistema di completare il lavoro, portando i core al **100% di carico** (Artifact D) nel tentativo di gestire l'overhead di parsing, mentre la banda rimane irrisoria (65 Mbps).

II. L’Inganno (Smokescreen):

L'Artifact C (Log PaloAlto) rivela una manovra di **diversione tattica**:

Il Diversivo: Il SOC è stato distratto da attacchi UDP Flood (DNS e NTP Amplification) regolarmente bloccati dal Firewall.

Il Cavallo di Troia: Mentre il team monitorava i drop sul perimetro, l'attacco reale passava come traffico **HTTPS/443 "ALLOW"**. I firewall non hanno segnalato anomalie perché il traffico sembrava legittimo traffico TLS 1.3 diretto alle API di pagamento.

III. Attribuzione e Movente:

Attore: RedStorm (Intelligence Artifact A). Il gruppo ha rivendicato l'operazione "Black Monday".

Obiettivo Geopolitico: Sabotaggio economico durante il G7 Finanze. L'attacco non mira al furto di dati, ma alla **perdita di fiducia sistemica** nelle infrastrutture digitali del paese target, colpendo il cittadino comune (impossibilità di fare acquisti o prelevare). E’ anche una possibile tattica per valutare i tempi di reazione e diffondere panico nella popolazione bloccando l’economia del paese target.

IV. Mitigazione Immediata

Si dispone l'attuazione immediata delle seguenti contromisure:

Protocol Downgrade: **Il Protocol Downgrade** a HTTP/1.1 è una misura di emergenza drastica ma estremamente efficace per neutralizzare un attacco *Rapid Reset*.

1. Eliminazione del Multiplexing

In HTTP/2, un attaccante può inviare centinaia di richieste all'interno di un singolo pacchetto TCP. Forzando il downgrade a **HTTP/1.1**, si ripristina la semantica "una richiesta alla volta" per ogni connessione. L'attaccante perde la capacità di inondare il server con frame RST_STREAM simultanei, poiché il protocollo precedente non li supporta.

2. Trasferimento del Carico (da CPU a Connessioni)

L'attacco Rapid Reset mira alla **CPU** (gestione dei frame). Con HTTP/1.1, l'attacco torna a essere di tipo tradizionale: per inviare molte richieste, l'attaccante deve aprire molte connessioni TCP. Questo è molto più facile da gestire per i difensori perché:

Il firewall può limitare il numero di connessioni per singolo IP.

L'occupazione di memoria per le connessioni TCP è più facile da monitorare rispetto ai cicli CPU "invisibili" spesi nel parsing di HTTP/2.

3. "Rallentamento" Forzato dell'Attaccante

In HTTP/1.1, il client deve attendere la risposta del server (o almeno la gestione della richiesta corrente) prima di inviarne un'altra sulla stessa connessione. Questo introduce una **latenza forzata** che annulla l'efficienza del modulo "Rapid" di DDoSia, rendendo l'attacco molto meno impattante.

È una soluzione da utilizzare come **"interruttore di emergenza" (Kill Switch)** durante il picco dell'attacco, per poi ripristinare HTTP/2 una volta configurati i rate limit corretti o applicate le patch di sicurezza.

RST_STREAM Threshold: Configurare limiti stretti sul numero di frame di reset consentiti per connessione TCP prima della terminazione della stessa.

1. Colpisce l'Anomalia Statistica

In una sessione HTTP/2 normale, un frame RST_STREAM è un evento raro. L'attacco *Rapid Reset*, invece, genera un rapporto quasi 1:1 tra richieste inviate e reset. Impostare una soglia (ad esempio, massimo 20 reset per connessione) permette di identificare e abbattere istantaneamente solo le connessioni malevole.

2. Protezione della CPU (Early Drop)

Senza questa soglia, il server continua a processare i frame finché la CPU non satura. Con il limite sui reset, il server può **interrompere la connessione TCP** non appena il client supera il limite. Questo risparmia cicli di clock preziosi, impedendo al server di entrare nello stato di "blocco" che abbiamo visto nei log di Nginx (100% CPU).

3. Precisione Chirurgica rispetto al Downgrade

A differenza del Protocol Downgrade (che rallenta tutti), il limite sui reset permette di mantenere attivo HTTP/2 per il 99% degli utenti. Solo i bot che utilizzano il modulo "Rapid" (che per definizione deve resettare i flussi per essere efficace) verranno espulsi dalla rete.

WAF Rate Limiting: L'implementazione del **Rate Limiting a livello WAF (Layer 7)** è la linea di difesa più avanzata perché permette di analizzare il comportamento del client con una granularità che un semplice firewall non possiede.

1. Filtraggio "Intelligente" (Fingerprinting)

A differenza del blocco a livello TCP, il WAF può correlare l'indirizzo IP, l'User-Agent e il comportamento specifico dell'attacco. Un rateo superiore a **100 richieste/reset al secondo** è fisicamente impossibile per un essere umano che naviga in un sito bancario. Identificando questo pattern, il WAF può inserire l'IP dell'attaccante in una **blacklist temporanea**.

2. Offloading del Carico

Implementando il limite sul WAF (che spesso si trova "in cloud" o su appliance dedicate prima del server), l'attacco viene bloccato **prima di raggiungere Nginx**. Questo previene la saturazione della CPU del server di backend

3. Mitigazione degli "Smokescreen"

Un WAF configurato correttamente può distinguere tra un picco di traffico legittimo (es. molti utenti che accedono contemporaneamente per controllare il saldo) e un attacco automatizzato. Mentre il traffico legittimo presenta una varietà di percorsi (/home, /login, /css/...), l'attacco visto nei log colpisce ripetutamente lo stesso endpoint (/api/v1/balance)

4. Risposta Dinamica

Invece di un semplice blocco (DENY), il WAF può rispondere con un **CAPTCHA** o un ritardo forzato. Questo è fondamentale perché:

Rende l'attacco computazionalmente costoso per l'attaccante.

Evita il blocco totale nel caso in cui l'IP dell'attaccante sia condiviso (es. un grande ufficio o una rete pubblica con molti utenti reali).

Aggiornamento Firme:

Riconoscimento del Pattern nel Flusso Binario: HTTP/2 è un protocollo binario, il che lo rende difficile da leggere per l'occhio umano. Le firme IPS specifiche per la **CVE-2023-44487** sono istruite per rilevare la sequenza esatta di frame **HEADERS** seguiti immediatamente da ***RST_STREAM***. Caricare queste firme permette all'IPS di agire come un sensore specializzato che intercetta la "firma comportamentale" dell'attacco anche se nascosta all'interno di una sessione TLS apparentemente valida.

Protezione Multi-Vettore (Oltre il Rapid Reset) : Mentre il Rate Limiting gestisce la quantità, le firme IPS proteggono dalla qualità della minaccia. DDoSia v4.4.2 spesso accompagna il Rapid Reset con altri tentativi di exploit. Avere firme aggiornate sul perimetro permette di bloccare non solo l'attacco HTTP/2, ma anche i tentativi di comunicazione verso i server di Comando e Controllo (C2) del gruppo RedStorm, troncando l'attacco alla radice.

Automazione della Difesa Perimetrale L'aggiornamento delle firme permette una risposta "Zero-Touch". Una volta che l'IPS rileva il pattern maligno:

Drop Immediato: Il pacchetto viene scartato prima ancora di arrivare al Load Balancer.

Auto-Shunning: L'IPS può istruire il firewall per bloccare totalmente l'indirizzo IP dell'attaccante per un periodo di tempo (es. 30 minuti), riducendo istantaneamente il "rumore" di fondo dell'attacco.

Visibilità e Reporting

L'uso di firme IPS specifiche permette di generare log precisi. Invece di vedere generici errori di connessione, il team di sicurezza vedrà alert chiari del tipo: Critical: HTTP/2 Rapid Reset Attack Detected (CVE-2023-44487). Questo è essenziale per la fase di **Incident Response** e per dimostrare alle autorità competenti che l'attacco è stato identificato correttamente.